

1. During a penetration test at Greenview Credit Union in Chicago, Illinois, ethical hacker Rebecca Hayes simulates an attacker who contacts employees using a voice channel. The number displayed on their devices appears identical to the institution's official line, convincing staff that the request is legitimate. Rebecca then asks for account credentials under the pretense of a mandatory security check. Which mobile attack vector is she demonstrating?

- ☐ OTP Hijacking
- ☐ Bluebugging
- ☐ SMiShing
- ☐ Call Spoofing

2. During a post-exploitation phase on a compromised finance department workstation, ethical hacker Anika uses her Meterpreter session to extract sensitive credential data. After running a command, she receives a long list of alphanumeric strings representing LM and NTLM values. These outputs are later transferred to a cracking rig for offline password recovery, allowing the red team to simulate credential theft across multiple systems. Which Meterpreter command most likely produced these results?

- ☐ getsystem
- ☐ screenshot
- ☐ hashdump
- ☐ keyscan_start

3. During a compliance review at a law firm in Chicago, an ethical hacker tests the firm's secure email gateway. She observes that sensitive legal documents are being transmitted in clear text over the Internet, allowing anyone intercepting the traffic to read the contents. The firm is concerned about unauthorized

individuals being able to view these communications. Which principle of information security is being violated?

- ☐ Availability
- ☐ Confidentiality
- ☐ Integrity
- ☐ Non-Repudiation

4. During a red team simulation at a bank in Chicago, Illinois, the SOC team suspects that some of the incoming traffic may be spoofed. To verify this, an analyst begins monitoring the sequence values assigned to packets, looking for irregularities that indicate they were not generated by the legitimate source. Which spoofing detection technique is the analyst using?

- ☐ Packet Filtering
- ☐ Direct TTL Probes
- ☐ TCP Flow Control Method
- ☐ IP Identification Number (IPID) Monitoring

5. During a penetration test at Pinnacle Bank in Chicago, ethical hacker Sarah injects crafted TCP packets into an active communication between a customer's browser and the online banking server. The victim's connection becomes unstable, allowing Sarah's system to maintain communication with the server in place of the legitimate client. She later demonstrates to the IT team how attackers could forcibly take control of live sessions through this approach. Which type of session hijacking is Sarah performing in this scenario?

- ☐ Man-in-the-Browser Attack
- ☐ Passive Session Hijacking
- ☐ Blind Hijacking

☐ Active Session Hijacking

6. During a forensic investigation of an attack on a media company in New York, analysts discovered that a non-privileged process loaded a malicious library instead of the intended library because the attacker placed the rogue file in a directory Windows searched before the legitimate location. When the trusted application started, the attacker's code executed with the application's privileges. No registry changes or kernel exploits were involved. Which technique most likely enabled the privilege escalation?

☐ Access Token Manipulation

☐ Privilege Escalation Using DLL Hijacking

☐ Privilege Escalation by Exploiting Vulnerabilities

☐ Privilege Escalation by Bypassing User Account Control

7. Noah Kim, an ethical hacker at Quantum Cyber Solutions in Austin, Texas, is assessing iPhones used for proprietary development. On one device, he demonstrates a technique that allows it to boot normally without a computer, but the elevated access is temporarily lost after restart until the user launches a special on-device app to reapply the modifications. Which jailbreaking method is this?

☐ Tethered Jailbreaking

☐ Semi-untethered Jailbreaking

☐ Untethered Jailbreaking

☐ Semi-tethered Jailbreaking

8. During a red team exercise at Apex Logistics in Denver, ethical hacker Rachel launches controlled packet injection attacks to simulate session hijacking attempts. The client's IT team wants a way to automatically detect such

abnormal behaviors across the network in real time, instead of relying on manual analysis. They decide to deploy a monitoring system capable of flagging suspicious session activity based on predefined rules and traffic signatures.

Which detection method best fits the IT team's requirement?

- ☐ Perform manual packet analysis using sniffing tools
- ☐ Monitor for ACK storms
- ☐ Use an Intrusion Detection System (IDS)
- ☐ Check for predictable session tokens

9.You are performing a security audit for a regional hospital in Dallas, Texas. While monitoring the network, you discover that an unknown actor has been silently capturing clear-text credentials and analyzing unencrypted traffic flowing across the internal Wi-Fi network. No modifications have been made to the data, and the attack remained undetected until your assessment. Based on this activity, what type of attack is most likely being conducted?

- ☐ Insider attack
- ☐ Close-in attack
- ☐ Distribution attack
- ☐ Passive attack

10.During a security assessment for an e-commerce company in Boston, Massachusetts, your team conducts a reconnaissance phase to identify potential entry points into the organization's communication infrastructure. You focus on gathering details about the systems responsible for handling incoming email traffic, avoiding active network probing, and relying on passive DNS data collection. Given this objective, which DNS record type should you query to extract information about the target's mail server configuration?

- ☐ MX

☐ NS

☐ TXT

☐ SO

11. At a power distribution facility in Phoenix, Arizona, ethical hacker Sameer Das is performing an OT security assessment. He demonstrates that a programmable controller accepts modifications delivered over the network without checking the origin or cryptographic validity of the package. By uploading altered instructions, he changes how the controller processes commands during operations. Which IoT/OT threat best represents this technique?

☐ Exploit kits

☐ Remote access using backdoor

☐ Forged malicious device

☐ Firmware update attack

12. During a penetration test at a shipping company in Miami, ethical hacker Daniel delivers a disguised email attachment containing a hidden payload. Once executed by employees, the compromised workstations begin to silently communicate with a remote server under Daniel's control. Over the following week, he confirms that multiple infected endpoints can receive synchronized commands and perform background tasks simultaneously, including sending bursts of outbound traffic on demand. Which type of malicious component is Daniel most likely simulating in this assessment?

☐ Scareware

☐ Potentially Unwanted Applications (PUAs)

☐ Botnet Agents

☐ Spyware

13. During a penetration test at Rocky Mountain Insurance in Denver, ethical hacker Sophia Nguyen attempts to evade detection by fragmenting malicious traffic into smaller packets. The IT security team counters her strategy with a system that monitors traffic for deviations from established baselines, flagging behavior that does not match normal network activity. This allows them to stop Sophia's evasion attempts in real time. Which detection technique is the IT team most likely using in this case?

- ☐ Signature-Based Detection
- ☐ Stateful Packet Inspection
- ☐ Anomaly-Based Detection
- ☐ Deep Packet Inspection

14. During a penetration test at Lone Star Healthcare in Austin, ethical hacker Liam evaluates the hospital's perimeter defenses by generating controlled traffic flows through the firewall. He uses a tool that can create and replay diverse traffic patterns to test how well the firewall enforces its rules against both legitimate and malicious traffic types. This allows him to demonstrate whether the device properly identifies evasion attempts under simulated attack conditions. Which tool is Liam most likely using in this test?

- ☐ Colasoft Packet Builder
- ☐ Metasploit
- ☐ Nmap
- ☐ Traffic IQ Professional

15. During a red team engagement at a law firm in Dallas, ethical hacker Sarah connects a compromised workstation to a core switch. Within minutes, the switch begins experiencing instability, and multiple VLANs report traffic leakage

across isolated departments. Sarah observes that her machine is now receiving packets not originally destined for it, giving her visibility into multiple active sessions. Logs show the switch's CAM table was overwhelmed during the attack. Which sniffing technique did Sarah most likely use?

- ☐ ARP Poisoning
- ☐ VLAN Hopping
- ☐ MAC Flooding
- ☐ DNS Poisoning

16. In sunny San Diego, California, security consultant Maya Ortiz is engaged by PacificGrid, a regional utilities provider, to analyze suspicious access patterns on their employee portal. While reviewing authentication logs, Maya notices many accounts each receive only a few login attempts before the attacker moves on to other targets; the attempts reuse a very small set of likely credentials across a large number of accounts and are spread out over several days and IP ranges to avoid triggering automated lockouts. Several low-privilege accounts were successfully accessed before the pattern was detected. Maya prepares a forensic timeline to help PacificGrid contain the incident.

- ☐ Brute Force Attack
- ☐ Cross-Site Request Forgery (CSRF)
- ☐ Session Hijacking
- ☐ Password Spraying

17. During an internal red team engagement at a software company in Boston, ethical hacker Meera gains access to a developer's workstation. To ensure long-term persistence, she plants a lightweight binary in a hidden directory and configures it to automatically launch every time the system is restarted. Days later, even after the host was rebooted during patching, the binary executed again without requiring user interaction, giving Meera continued access. Which

technique most likely enabled this persistence?

- ☐ Registry run keys
- ☐ creating a new service
- ☐ Scheduled Tasks
- ☐ Startup Folder

18.As part of a red team campaign against a pharmaceutical company in Boston, ethical hacker Alex begins with a successful spear-phishing attack that delivers an initial payload to a manager's laptop. After gaining access, Alex pivots to harvesting cached credentials and using them to move laterally across the internal network. Soon, routers, printers, and several file servers are compromised, expanding the red team's control beyond the original host. At this point, Alex has not yet targeted sensitive research data, but the team has built a broader foothold within the environment. Which phase of the Advanced Persistent Threat (APT) lifecycle is Alex simulating?

- ☐ Expansion
- ☐ Persistence
- ☐ Initial Intrusion
- ☐ Search & Exfiltration

19.At a financial headquarters in Denver, Colorado, ethical hacker Jordan Lee moves beyond cataloging IoT devices and begins testing them for weaknesses. He runs specialized tools against smart lighting and HVAC systems to check for outdated firmware, default passwords, and open service ports. Which step of the IoT hacking methodology is Jordan carrying out?

- ☐ Launch attacks
- ☐ Gain remote access

- ☐ Vulnerability scanning
- ☐ Information gathering

20. While auditing legacy network devices at a public hospital in Miami, Jason, a penetration tester, needs to verify what SNMP traffic is leaking across the internal segment. Instead of running structured queries, he decides to capture live network traffic and manually review the protocol fields. This method allows him to see SNMP requests and responses in transit but requires manual parsing of OIDs, community strings, and variable bindings. Which method should Jason use in this situation?

- ☐ Wireshark
- ☐ Nmap
- ☐ SoftPerfect Network Scanner
- ☐ SnmpWalk

21. During an authorized penetration test of an organization's Operational Technology (OT) environment, the tester has already identified exposed industrial assets and now begins actively probing controllers, services, and interfaces to identify exploitable weaknesses. No exploitation attempts or persistence mechanisms have been performed yet. According to the OT hacking methodology, which phase is currently being carried out?

- ☐ Vulnerability Scanning
- ☐ Launch Attacks
- ☐ Information Gathering
- ☐ Gain Remote Access

22. During a quarterly vulnerability management cycle at a multinational logistics

firm, Priya's team has already applied patches and fixes to address confirmed vulnerabilities. Now, she directs the analysts to run follow-up scans and review the attack surface to confirm that the applied remedies have effectively eliminated the risks. Only after this step will she prepare a compliance report for the executive board. Which phase of the Vulnerability-Management Life Cycle is Priya executing?

- ☐ Verification
- ☐ Remediation
- ☐ Risk Assessment
- ☐ Monitoring

23. During a red team exercise at Horizon Financial Services in Chicago, ethical hacker Clara crafts an email designed to trick the company's CEO. The message, disguised as an urgent memo from the legal department, warns of a pending lawsuit and includes a link to a fake internal portal requesting the executive's credentials. Unlike generic phishing, this attack is tailored specifically toward a high-ranking individual with decision-making authority. Which social engineering technique is Clara demonstrating in this scenario?

- ☐ Spear Phishing
- ☐ Clone Phishing
- ☐ Whaling
- ☐ Consent Phishing

24. At a New York-based e-commerce company preparing for Black Friday sales, analyst Sarah evaluates cloud billing practices. She notices that the provider tracks compute hours, storage usage, and bandwidth consumption in detail, enabling the company to pay only for what is consumed while also supporting audits. Which cloud computing characteristic best explains this feature?

- ☐ Resource pooling
- ☐ On-demand self-service
- ☐ Broad network access
- ☐ Measured service

25. In Pittsburgh, Pennsylvania, a major steel manufacturer operates a production plant with numerous automated loops that regulate temperature, pressure, and conveyor speed. During an audit, ethical hacker Marcus Reed observes that these loops are coordinated by a centralized supervisory network that links multiple controllers across the facility. Based on this design, which OT system concept is being applied?

- ☐ Manual loop
- ☐ Closed loop
- ☐ Distributed Control System (DCS)
- ☐ Open loop

26. You are Alex, a forensic responder at HarborHealth in Seattle, Washington. During a live incident response you must secure an enterprise Windows server's system partition and attached data volumes without rebooting user machines or disrupting domain authentication. The IT team prefers a solution that integrates with Windows platform features (including hardware-backed startup protection and centralized key escrow via Active Directory/management policies) and provides transparent full-disk protection for the OS volume. Which disk-encryption solution should you deploy?

- ☐ VeraCrypt
- ☐ BitLocker Drive Encryption
- ☐ FileVault

☐ Rohos Disk Encryption

27. During a red team exercise for a global insurance provider in Chicago, ethical hacker Maria tests the effectiveness of the company's endpoint defenses. She launches an attack by injecting malicious PowerShell commands into a trusted process without dropping any executables on disk. The code executes entirely in memory, generating abnormal spikes in resource usage. After a reboot, Maria notes that the system returns to normal and traditional antivirus logs show no evidence of infection. Which type of malware technique did Maria most likely use in this test?

☐ Trojan

☐ Ransomware

☐ Fileless Malware

☐ Rootkit

28. In the crisp mountain air of Denver, Colorado, ethical hacker Lila Chen investigates the security framework of MediVault, a U.S.-based healthcare platform used by regional clinics to manage patient data. During her review, Lila discovers that sensitive records are weakly protected, allowing attackers to intercept and manipulate the information in transit. She warns that such weaknesses could be exploited to commit credit-card fraud, identity theft, or similar crimes. Further analysis reveals that MediVault is vulnerable to well-documented flaws such as cookie snooping and downgrade attacks.

☐ Cryptographic Failures

☐ Security Misconfiguration

☐ Identification and Authentication Failures

☐ Broken Access Control

29. At Norwest Freight Services, Simon, a junior analyst, is tasked with running a vulnerability scan on several departmental servers. This time, he is provided with administrator-level credentials to input into the scanner. The scan takes significantly longer than usual but returns detailed results, including weak registry permissions, outdated patches, and insecure configuration files that would not have been visible to an outsider. SIEM logs confirm that successful logins occurred during the scanning process. Which type of vulnerability scan BEST explains the behavior observed in Simon's assessment?

- ☐ Internal Scanning
- ☐ External Scanning
- ☐ Non-Credentialed Scanning
- ☐ Credentialed Scanning

30. In the financial hub of Charlotte, North Carolina, ethical hacker Raj Patel is contracted by TrustBank, a regional U.S. bank, to evaluate their online loan application portal. During testing, Raj submits crafted input into the portal's form fields and notices that the server's HTTP responses are unexpectedly altered. His payloads cause additional headers to appear and even inject unintended content into the output, creating opportunities for attackers to manipulate web page behavior and deliver malicious data to users. Which type of vulnerability is Raj most likely exploiting in TrustBank's online loan application portal?

- ☐ XML Poisoning
- ☐ Server-Side Request Forgery (SSRF)
- ☐ XML External Entity (XXE) Injection
- ☐ HTTP Response Splitting

31. You are an ethical hacker at SilverRock Security, engaged by BayState Credit Union in Boston, Massachusetts, to evaluate their online loan application portal. While testing the customer dashboard, you inject crafted input into a numeric

parameter. Instead of returning only the expected loan details, the response also displays sensitive employee information from another table, merged into the same page results. This behavior indicates that the attacker's input successfully combined multiple datasets into a single output. Based on the observed behavior, which type of SQL injection attack are you exploiting?

- ☐ UNION SQL Injection
- ☐ Second-Order SQL Injection
- ☐ Error-Based SQL Injection
- ☐ Blind SQL Injection

32. During a penetration test at IntelliCore Systems in Raleigh, North Carolina, ethical hacker Javier directs a wave of repetitive web requests against the company's portal that overload backend scripts which process search queries and form submissions. As a result, legitimate customers experience long delays and occasional timeouts while attempting to log in or complete transactions. Which DoS/DDoS technique is Javier most likely demonstrating?

- ☐ HTTP GET/POST Attack
- ☐ Slowloris
- ☐ Peer-to-Peer Attack
- ☐ UDP Flood

33. You are part of a red team hired to assess the cybersecurity posture of a large retail chain headquartered in New York. The client wants to know whether their defenses can anticipate future attack patterns before they occur. To meet this objective, your team deploys an AI-enabled platform that analyzes previous breaches and anomaly data to forecast potential attack vectors. Which benefit of AI-driven ethical hacking is most critical in this case?

- ☐ Enhanced reporting

- ☐ Simulation and testing
- ☐ Predictive analysis
- ☐ Scalability

34. In Miami, Florida, a luxury resort deploys smart climate control units in guest rooms. During a red team engagement, ethical hacker Sophia Bennett discovers that once a compromised device is restarted, it continues running altered instructions without any integrity check before the operating system loads. This allows tampered firmware to run as if it were legitimate. Which secure development practice would most directly prevent this weakness?

- ☐ Utilize secure communication protocols
- ☐ Ensure secure boot
- ☐ Secure firmware or software updates
- ☐ Allow code signing

35. You are Maya, a security engineer at HarborPoint Cloud Services in Chicago, Illinois, performing a post-incident hardening review after an internal audit flagged multiple services that rely on legacy public-key algorithms. The engineering team must prioritize actions company-wide to reduce long-term risk from future quantum-capable adversaries while development continues on a large refactor of several services. Which proactive control should Maya recommend as the highest-priority change to embed into the organization's development lifecycle to improve future resistance to quantum-based attacks?

- ☐ Break data into fragments and distribute it across multiple locations
- ☐ Use quantum-specific firewalls to protect quantum communication channels
- ☐ Encrypt stored data with quantum-resistant algorithms
- ☐ Include quantum-resistance checks in SDLC and code review processes

36. During a red team assessment at a banking client in Chicago, ethical hacker David gains access to the internal LAN. He sets up a test machine and injects crafted messages into the network. Soon, all traffic between a finance workstation and the authentication server is silently routed through his system without changing switch configurations. He observes usernames and passwords passing through his interface, even though no proxy or VPN is in use. Which sniffing technique did David most likely use?

- ☐ Switch Port Stealing
- ☐ IRDP Spoofing
- ☐ ARP Spoofing
- ☐ STP Attack

37. During a stealth penetration test at a defense research facility, ethical hacker Daniel installs a payload that survives even after multiple operating system reinstalls. The implant resides deep inside the system hardware and executes before the OS is loaded, ensuring that forensic scans and antivirus tools at the OS level cannot detect or remove it. Administrators notice unusual activity on network cards and storage devices, but repeated scans show no malware traces within the file system. Which type of rootkit most likely enabled this level of persistence?

- ☐ Hardware/Firmware Rootkit
- ☐ Hypervisor-Level Rootkit
- ☐ Kernel-Level Rootkit
- ☐ Boot-Loader-Level Rootkit

38. During a penetration test at an e-commerce company in Boston, ethical hacker Sophia launches an HTTP flood against the checkout page of the site. The

simulated traffic consists of repeated GET and POST requests designed to overload application-layer resources. In response, the IT team activates a security tool that inspects and filters malicious HTTP traffic while allowing legitimate customer requests to pass, ensuring service continuity during the exercise. Which DoS/DDoS protection tool is most likely being used in this scenario?

- ☐ Firewall
- ☐ Intrusion Prevention System
- ☐ Load Balancer
- ☐ Web Application Firewall

39. Joe, a cybersecurity analyst at Norwest Freight Services, has been assigned to run a vulnerability scan across the organization's infrastructure. He is specifically tasked with detecting weaknesses such as missing patches, unnecessary services, weak encryption, and authentication flaws across multiple servers. His scan identifies open ports and active services throughout the environment, providing a clear map of potential entry points for attackers. Which type of vulnerability scanning BEST matches Joe's assignment?

- ☐ External Scanning
- ☐ Host-based Scanning
- ☐ Application Scanning
- ☐ Network-based Scanning

40. During a red team assessment at a retail bank in New York, ethical hacker Aisha launches a flood of TCP connection initiation packets against the bank's online portal. The target accepts each initial handshake packet but never receives the final ACK to complete the three-way handshake, exhausting the server's backlog of half-open connections and preventing legitimate users from establishing new sessions. Which type of DoS attack is Aisha most likely

simulating?

☐ SYN Flood Attack

☐ ACK Flood

☐ TCP SACK Panic

☐ RST Attack

41. During a penetration test at a telecom provider in Denver, Colorado, Maria, a senior ethical hacker, notices that her scans are immediately flagged by intrusion detection systems. She modifies her technique, and as a result, the IDS devices are unable to reassemble the packets correctly, allowing her probes to slip through without detection. Which scanning evasion technique is Maria applying in this case?

☐ Source Routing

☐ Decoy Scanning

☐ IP Spoofing

☐ Packet Fragmentation

42. During a penetration test at a healthcare provider in Phoenix, ethical hacker Sofia crafts a stream of IP packets with manipulated offset fields and overlapping payload offsets so that the records server's protocol stack repeatedly attempts to reconstruct the original datagrams. The repeated reconstruction attempts consume CPU and memory, causing the system to crash intermittently and disrupt patient portal access, even though overall bandwidth remains normal. Packet analysis shows deliberately malformed offsets that trigger processing errors rather than a simple flood of traffic. Which type of attack is Sofia most likely simulating?

☐ ICMP Flood

☐ Fragmentation Attack

☐ Teardrop Attack

☐ Ping of Death

43. At Apex Financial Services in Houston, Texas, ethical hacker Javier Ruiz evaluates mobile security practices under the company's BYOD policy. He demonstrates that employees often install applications that request access to contact lists, cameras, and messaging services, even though these functions are unrelated to the apps' intended purpose. This behavior allows a malicious program to harvest sensitive corporate information. Which security guideline would most directly prevent this issue?

☐ Use encryption mechanisms to store data

☐ Review permissions requested by apps before installing them

☐ Set passwords for apps to restrict others from accessing them

☐ Enforce automatic device locking or implement biometric authentication

44. You are an ethical hacker at HorizonSec Consulting, hired by Liberty Insurance in Philadelphia, Pennsylvania, to test the resilience of their online claim submission portal. During testing, you modify the claim ID parameter in the URL with conditions such as AND 1=1 and AND 1=2. When the first condition is used, the portal displays claim details as normal; when the second condition is used, the page displays no results. You repeat this process to determine how the application responds to true and false conditions without error messages or delays. Based on the observed behavior, which SQL injection technique are you employing?

☐ Boolean Exploitation

☐ Error-based SQL Injection

☐ Time-based Blind SQL Injection

☐ UNION SQL Injection

45. During a physical penetration test at Sterling Electronics in Cleveland, ethical hacker Priya waits near the employee entrance during a shift change. When a group of staff enters the building using their access cards, Priya closely follows behind without swiping her own badge. None of the employees confront her, assuming she belongs there. Once inside, Priya proceeds to the break area where she documents the success of the exercise. Which social engineering technique is Priya demonstrating?

- ☐ Shoulder Surfing
- ☐ Dumpster Diving
- ☐ Piggybacking
- ☐ Tailgating

46. You are a security analyst at Sentinel Cyber Group, monitoring the web portal of Aspen Valley Bank in Salt Lake City, Utah. During log review, you notice repeated attempts by attackers to inject malicious strings into the login fields. However, despite these attempts, the application executes queries safely without altering their logic, since user inputs are kept separate from the SQL statements and bound as fixed values before execution. Based on the observed defense mechanism, which SQL injection countermeasure is the application employing?

- ☐ Use parameterized queries or prepared statements
- ☐ Perform user input validation
- ☐ Encoding the single quote
- ☐ Restrict database access

47. You are an ethical hacker at Northpoint Assessments, engaged to map the wireless footprint around Harborview Plaza in San Francisco, California. To enumerate nearby networks and prompt devices to reveal SSIDs and capabilities, you actively send crafted management frames from your laptop and

log each AP's immediate responses (including probe responses and capability information), rather than only listening for broadcasts. Based on the described activity, which Wi-Fi discovery technique are you performing?

- ☐ Wash Command
- ☐ Active Footprinting
- ☐ Network Discovery Software
- ☐ Passive Footprinting

48. At Bayview University in San Francisco, California, ethical hacker Sofia Patel is evaluating security controls on Android 11 tablets used by staff. To simulate an attack, she installs KingoRoot.apk directly on one of the devices. The application leverages system vulnerabilities to elevate privileges without requiring a computer connection. Based on the module, which feature of this rooting approach makes the attack effective?

- ☐ It relies on weak SSL validation to bypass application controls
- ☐ It is an APK that can run directly on the device without a PC
- ☐ It exploits Bluetooth pairing flaws to gain device-level privileges
- ☐ It uses a tethered jailbreak to restart the device with patched kernel functions

49. During a penetration test at a regional bank in Richmond, ethical hacker Thomas is tasked with identifying weaknesses in how employee credentials are transmitted. He sets up Wireshark on a mirrored port and captures HTTP login sessions from the customer services VLAN. To quickly reconstruct entire conversations between browsers and the server, Thomas uses a feature that reassembles packet data into a readable stream, allowing him to view usernames and passwords directly in plain text. Which Wireshark feature is Thomas most likely using in this case?

- ☐ Follow TCP Stream

- ☐ Monitoring the Specific Ports
- ☐ Display Filtering by Protocol
- ☐ Filtering by IP Address

50. During an assessment for a tech company in Seattle, Washington, an ethical hacker seeks to uncover details about the organization's domain ownership to identify potential points of contact. She uses an online service to retrieve publicly available records without direct interaction with the target. Which method is she most likely employing to achieve this?

- ☐ Network footprinting
- ☐ Whois lookup
- ☐ Email footprinting
- ☐ DNS interrogation

51. At a Chicago-based healthcare provider, security engineer Emily reviews the migration of critical applications to a cloud service. During her evaluation, she notes that administrators can provision new servers, increase storage, and expand compute power instantly through a web dashboard without any manual involvement from the cloud provider. Which NIST-defined characteristic of cloud computing best explains this capability?

- ☐ Broad network access
- ☐ Measured service
- ☐ Resource pooling
- ☐ On-demand self-service

52. During a red team exercise at a financial services firm in Phoenix, Arizona, an ethical hacker sends a phishing email with a disguised attachment to

employees. The purpose is to transmit the payload into the environment so later attack steps can proceed. In the cyber kill chain model, which phase does this represent?

- ☐ Reconnaissance
- ☐ Weaponization
- ☐ Delivery
- ☐ Exploitation

53. In the vibrant startup scene of Austin, Texas, ethical hacker Daniel Ruiz is hired by TechNexus, a U.S.-based logistics software provider, to evaluate their internal administration portal. During testing, Daniel observes that certain input fields forward user-supplied data directly to underlying system functions. By carefully crafting his entries, he is able to trigger execution of unexpected system commands, resulting in unauthorized control over the operating environment. His findings reveal that the flaw stems from poor validation of input processed by system-level functions.

- ☐ Shell Injection
- ☐ Cross-Site Scripting (XSS)
- ☐ SQL Injection
- ☐ LDAP Injection

54. During a security assessment of a fintech startup in San Francisco, ethical hacker Michael analyzes the company's cloud platform. He observes that the system automates deployment, scaling, service discovery, and workload management across multiple nodes, ensuring smooth operation of critical services without requiring manual coordination. Which Kubernetes capability is primarily responsible for these functions?

- ☐ Container vulnerabilities

- ☐ Kube-controller-manager
- ☐ Container orchestration
- ☐ Self-healing

55.You are an ethical hacker at HarborLine Assessments, engaged to audit the Wi-Fi at Portside Freight in Tacoma, Washington. During an overnight reconnaissance, you enable your wireless interface's monitor mode and run a command that silently records beacon frames, probe responses and authentication frames from nearby APs and clients into a capture file for later offline analysis - you do not transmit any frames from your laptop. Based on the described activity, which Wi-Fi security auditing tool are you most likely using?

- ☐ Aircrack-ng
- ☐ Airodump-ng
- ☐ Airbase-ng
- ☐ Aireplay-ng

56.During a penetration test at Triangle FinTech in Raleigh, North Carolina, ethical hacker Ethan attempts to bypass the company's perimeter firewall. Instead of sending obvious malicious payloads, he encapsulates his traffic inside standard web requests on port 80, blending in with normal browsing activity. This method allows his packets to slip past perimeter defenses that are not performing deep application inspection. Which firewall evasion technique is Ethan most likely using?

- ☐ HTTP Tunneling
- ☐ Tiny Fragments
- ☐ Source Routing
- ☐ DNS Tunneling

57.A financial startup in Chicago hires an ethical hacker to evaluate its exposure on hidden networks. The client is particularly concerned that confidential administrative documents might be circulating on .onion sites. To remain passive, the hacker relies on advanced search filters to look for files with headers suggesting management-related content. Which of the following queries would best meet this objective?

- ☐ filetype:docx intitle:"login credentials"
- ☐ filetype:pdf intitle:"admin access" site:onion
- ☐ filetype:pdf intitle:"secure login" site:onion
- ☐ filetype:docx intitle:"user accounts" site:onion

58.A financial institution in San Francisco suffers a breach where attackers install malware that captures customer account credentials. The stolen data is then sold on underground forums for profit. No political or social statements are made, and the attackers remain anonymous while continuing to target similar organizations for financial gain. Based on this activity, what category of hacker is most likely responsible?

- ☐ White Hat hackers
- ☐ Black Hat hackers
- ☐ Script Kiddies
- ☐ Hacktivists

59.You are a wireless auditor at SeaFront Labs in San Diego, California, engaged to review the radio-layer protections used by a biotech research facility. While capturing traffic in monitor mode, you observe frames that include a CCMP-like header and AES-based encryption, and you note the use of a four-way handshake with a packet number (PN) for replay protection - features that were

introduced to replace older TKIP/RC4 approaches. Based on these observed characteristics, which wireless encryption protocol is the access point most likely using?

☐ WPA

☐ WEP

☐ WPA3

☐ WPA2

60. During a red team exercise at Orion Tech Systems in San Jose, ethical hacker Nadia creates a campaign of fraudulent messages targeting employees. She uses compromised social media accounts to distribute bulk invitations that contain links to a fake cloud collaboration site. Several employees click the links and are prompted to log in with their corporate credentials, which Nadia captures. Although the lure appears to be a professional networking opportunity, the tactic relies on unsolicited deceptive messages delivered at scale. Which social engineering threat is Nadia simulating in this campaign?

☐ Angler Phishing

☐ Catfishing

☐ Involuntary Data Leakage

☐ Spam and Phishing

61. During a red team engagement at a technology startup in Austin, ethical hacker Priya simulates an internal attacker by connecting a laptop to the corporate LAN. Within minutes, nearby workstations begin receiving incorrect network settings such as altered gateways and DNS servers. Employees trying to access the intranet are redirected to fake login portals hosted on Priya's machine. Security tools record temporary IP conflicts, but no alerts are triggered against the altered traffic paths. Which attack technique did Priya most likely use?

- ☐ Rogue DHCP Server Attack
- ☐ DHCP Starvation Attack
- ☐ Packet Sniffing
- ☐ DNS Cache Poisoning

62. During a reconnaissance engagement at a law firm in Houston, Texas, you are tasked with analyzing the physical movement of employees through their publicly shared media. By examining geotagged images and mapping them to specific locations, you aim to evaluate whether staff are unintentionally disclosing sensitive information about office routines. Which tool from the reconnaissance toolkit would best support this task?

- ☐ Social Searcher
- ☐ Sherlock
- ☐ Maltego
- ☐ Creepy

63. As part of a cybersecurity assessment for a healthcare provider in Denver, Colorado, you are asked to recommend a framework that addresses how organizations should identify, assess, and treat information security risks as part of their ISMS. Which international standard best meets this requirement?

- ☐ ISO/IEC 27701:2019
- ☐ ISO/IEC 27001:2022
- ☐ ISO/IEC 27005:2022
- ☐ ISO/IEC 27002:2022

64. At a federal research agency, cybersecurity officer Nikhil is drafting a vulnerability assessment report. In this section, he documents the scanning

methodology used, the information about the targets, the type and scope of scans performed, and the tools involved. He does not yet include specific vulnerabilities or affected assets, as this portion of the report is meant to provide context for how the assessment was conducted. Which section of the vulnerability assessment report is Nikhil working on?

- ☐ Assessment Overview
- ☐ Findings
- ☐ Risk Assessment
- ☐ Supporting Information

65.You are an ethical hacker at Titan Cyber Defense, hired by BrightWave Publishing in New York City to assess the security of their content management system (CMS). While testing the article search function, you input malformed strings such as multiple single quotes. The application responds with system feedback that unexpectedly reveals the database type and internal query structure, including table and column information. You use these disclosures to better understand how the backend query is built. Which of the following methods to detect SQL injection are you employing?

- ☐ Dynamic Testing
- ☐ Testing String
- ☐ Fuzz Testing
- ☐ Function Testing

66.Maya Patel from Secure Horizon Consulting is investigating a breach at Dallas General Hospital in Texas after a nurse misplaced a smartphone containing patient management software. Although the device remained active on the network, administrators had no way to identify its physical whereabouts, delaying incident response and allowing sensitive medical records to be exposed for hours. Which mobile security guideline would have most directly reduced the

impact of this incident?

- ☐ Register devices with a remote locate and wipe facility
- ☐ Install device tracking software that allows the device to be located remotely
- ☐ Use anti-virus and data loss prevention (DLP) solutions
- ☐ Utilize a secure VPN connection while accessing public Wi-Fi networks

67. During a penetration test for a global e-commerce platform in Dallas, ethical hacker Maria simulates a large-scale DoS campaign. Instead of sending attack traffic directly, she forges requests to multiple open services across the internet. These services unknowingly reply to the victim system, multiplying the amount of traffic hitting the target. Within minutes, the victim's server is overwhelmed by a flood of responses, even though Maria's own machine generated only a small amount of traffic. Which attack technique is Maria most likely demonstrating?

- ☐ Smurf Attack
- ☐ NTP Amplification Attack
- ☐ Distributed Reflection Denial-of-Service (DRDOS)
- ☐ Botnet

68. During a red team engagement at a healthcare organization in Chicago, ethical hacker Devon intercepts Kerberos authentication material from a compromised workstation. Instead of cracking the data, he reuses the stolen tickets to authenticate directly to other systems within the domain. This allows him to access shared resources and servers without needing the users' plaintext credentials. No NTLM hashes or broadcast poisoning were involved. Which attack technique did Devon most likely perform?

- ☐ Pass-the-Ticket Attack
- ☐ Kerberoasting

☐ Pass-the-Hash

☐ LLMNR/NBT-NS Poisoning

69. During a code review at a defense technology contractor in Virginia, penetration tester Lucas identifies that a newly deployed payroll application encrypts sensitive employee data using a weak custom algorithm. In addition, its session validation logic allows certain requests to bypass access controls altogether. These oversights are traced back to flawed system logic and poor encryption design decisions made during the development phase. Which vulnerability category BEST describes the issue Lucas discovered?

☐ Misconfigurations/Weak Configurations

☐ Design Flaws

☐ Application Flaws

☐ Poor Patch Management

70. During a red team assessment at Apex Technologies in Austin, ethical hacker Ryan tests whether employees can be tricked into disclosing sensitive data over the phone. He poses as a vendor requesting payment details and reaches out to several staff members. To evaluate defenses, the security team emphasizes that beyond general training, there is a practical step employees must apply in every interaction to avoid being deceived by such calls. Which countermeasure should Apex Technologies prioritize to directly prevent this type of social engineering attempt?

☐ Employees must verify the identity of individuals requesting information

☐ Conduct security awareness programs

☐ Establish policies and procedures

☐ Use two-factor authentication

71. During a security review for a healthcare provider in Denver, Colorado, Ava examines the header of a suspicious message to map the sender's outbound email infrastructure. Her goal is to identify which specific system on the sender's side processed the message so the team can understand where the transmission originated within that environment. Which detail from the email header should she examine to determine this?

- ☐ Sender's IP address
- ☐ Sender's mail server
- ☐ Authentication system used by sender's mail server
- ☐ Date and time of message sent

72. You are an ethical hacker at RedOak Cyber Solutions, contracted to perform a penetration test for MetroHealth Hospital in Cleveland, Ohio. While assessing the hospital's appointment booking portal, you craft and submit multiple malicious inputs into the patient search field. One of your payloads successfully manipulates the backend query, returning additional appointment data that was not intended to be displayed. Based on the observed behavior, which step of the SQL injection methodology are you performing?

- ☐ Database Enumeration
- ☐ Information Gathering and Vulnerability Detection
- ☐ Identifying Data Entry Paths
- ☐ Launching SQL Injection Attacks

73. At a Miami-based cryptocurrency exchange, investigator Jake uncovers that attackers exploited exposed API keys to issue unauthorized cloud commands, leading to resource abuse and lateral movement inside the cloud environment. Which cloud hacking technique is most directly demonstrated in this incident?

- ☐ Wrapping attack

- ☐ Cryptojacking
- ☐ Enumerating S3 buckets
- ☐ Compromising secrets

74. During a simulated attack against a university's IT network in California, ethical hacker Sophia deploys custom malicious code onto one lab workstation. Without requiring further user interaction, she observes the malware automatically copying itself into shared folders and spreading through weak admin credentials. Within a short time, dozens of computers across multiple departments are infected with the same payload, even though only one machine was initially targeted. Which type of malware is Sophia most likely demonstrating?

- ☐ Backdoor
- ☐ Fileless Malware
- ☐ Logic Bomb
- ☐ Worm

75. During a red team engagement at a manufacturing company in Dallas, penetration tester Tyler gains access to a Windows workstation. Later in the exercise, he reviews his exfiltrated logs and finds detailed records of employee logins, email drafts, and sensitive data entered into desktop applications. The collection occurred without requiring browser injection or physical device access, and no kernel drivers were installed. Which type of keylogger did Tyler most likely deploy?

- ☐ Hardware Keylogger
- ☐ Application Keylogger
- ☐ JavaScript Keylogger
- ☐ Kernel Keylogger

76. During a social engineering simulation at BrightPath Consulting in Denver, ethical hacker Liam emails employees a message that appears to come from the company's security team. The email urgently warns that "all systems will shut down within 24 hours" unless staff download a patch from a provided link. The message is deliberately false and contains no actual malware, but it causes confusion and prompts several employees to call IT for clarification. Which social engineering technique is Liam demonstrating?

- ☐ Pretexting
- ☐ Hoax
- ☐ Spam
- ☐ Baiting

77. At TechTrend Innovations in Silicon Valley, network administrator Jake Henderson reviews the configuration of their web infrastructure. While inspecting the web server setup, he identifies the directory that stores the publicly accessible website content such as HTML files, images, and client-side scripts. Jake highlights this area as a frequent target for attackers, since improper permissions could expose sensitive files to unauthorized users. Which web server component is Jake analyzing in this scenario?

- ☐ Document Root
- ☐ Application Server
- ☐ Virtual Document Tree
- ☐ HTTP Server (Core)

78. During a penetration test at TechTrend Innovations in California, ethical hacker Jake Henderson reviews the company's web server exposure to network-based threats. He finds that the server is running with multiple open services and

protocols that are not required for its operation, such as NetBIOS and SMB. Jake explains to the IT team that attackers could exploit these unnecessary services to gain unauthorized access to the server. Which hardening measure should the IT team implement to mitigate this risk?

- ☐ Conduct risk assessment for patching
- ☐ Use a dedicated machine as a web server
- ☐ Block all unnecessary ports, ICMP traffic, and protocols
- ☐ Eliminate unnecessary files

79. During a quarterly security audit at a financial services company in Charlotte, North Carolina, you are tasked with reviewing exposed services on legacy servers inherited from a third-party vendor. While scanning, you discover that TCP port 1434 is open on a database node that is not listed in the company's active inventory. The IT team has no records explaining why this service is running, and you are asked to determine whether the exposure of this port could indicate an unnecessary database-related risk. Based on standardized port assignments, which service is most likely running on this port and requires further review?

- ☐ ms-sql-m
- ☐ sql*net
- ☐ sqlsrv
- ☐ ms-sql-s

80. During a penetration test at Pacific Trust Bank in Seattle, ethical hacker Mia Chen suspects that a server hosting customer transaction data may be a honeypot. To investigate, she repeatedly sends crafted queries and observes how quickly the system responds. She notices that responses are consistently faster and more uniform than those of other production servers, raising her suspicion that the environment is designed to lure attackers. Which technique is Mia most likely using to determine if the server is a honeypot?

- ☐ Analyzing MAC Address
- ☐ Analyzing System Configuration and Metadata
- ☐ Fingerprinting the Running Service
- ☐ Analyzing Response Time

81. During a penetration test for a U.S.-based retail company, John gains access to a secondary server that responds unusually to structured queries. By sending a specially crafted request, he receives a full list of subdomains, MX records, and aliases belonging to the target organization. The response exposes sensitive internal mappings that could be leveraged for further attacks. Which tool was MOST likely used to perform this enumeration?

- ☐ nbtstat -A
- ☐ dig @ axfr
- ☐ smtp-user-enum.pl -u user -t host
- ☐ ldapsearch-h -x

82. During a red team exercise at a financial institution in New York, penetration tester Bob investigates irregularities in time synchronization across critical servers. While probing one server, he decides to use a diagnostic command that allows him to directly interact with the NTP daemon and query its internal state. This command enables him to perform monitoring and retrieve statistics, but it is primarily focused on controlling and checking the operation of the NTP service rather than listing peers with delay, offset, and jitter values. Which command should Bob use to accomplish this?

- ☐ ntpq [-inp] [-c command] [host] [...]
- ☐ ntptrace [-n] [-m maxhosts] [servername/IP_address]
- ☐ ntpdc [-ilnps] [-c command] [host] [...]
- ☐ ntpq -p [host]

83. During a red team engagement at a retail company in Atlanta, ethical hacker James crafts a session with the company's shopping portal and deliberately shares that session ID with an unsuspecting employee by embedding it in a link. When the employee clicks and logs in, their activity is bound to the attacker's pre-assigned session. Later, James retrieves the employee's input from that same session to demonstrate the flaw to management. Which session hijacking technique is James most likely using?

- ☐ Session Replay Attack
- ☐ Session Fixation Attack
- ☐ Session Donation Attack
- ☐ Session Prediction

84. You are an ethical hacker at ShieldPoint Security, hired by Pinecrest Travel Agency in Orlando, Florida, to perform a penetration test on their flight booking portal. During testing, you notice that normal SQL injection attempts are blocked by a security filter. To bypass it, you adjust your input so that key SQL keywords are broken apart with unexpected symbols, allowing the database to interpret them correctly while evading the filter. This manipulation allows you to retrieve hidden booking records despite the filter's restrictions. Based on the observed behavior, which SQL injection evasion technique are you employing?

- ☐ In-line Comment
- ☐ String Concatenation
- ☐ Null Byte
- ☐ Hex Encoding

85. You are Michael, an ethical hacker at a New York-based e-commerce company performing a security review of their payment-signing service. While

observing the signing process (without access to private keys), you note the service generates a fresh random value for each signature operation, the signature algorithm uses modular arithmetic in a subgroup defined by public domain parameters, and signatures are verified with a public verification key rather than by decrypting the message. Which asymmetric algorithm best matches the signing mechanism you observed?

☐ RSA

☐ Diffie-Hellman

☐ DSA

☐ ElGamal

86. At a fast-growing startup in Austin, Texas, an ethical hacker is asked to simulate how attackers might gather information to gain initial access. During the assessment, she poses as a recruiter on a professional networking site and convinces several employees to share details about the company's internal software and VPN setup. Which type of threat best represents this adversary's method of information gathering?

☐ System and Network Attacks

☐ Information Leakage

☐ Corporate Espionage

☐ Social Engineering

87. During a penetration test at a manufacturing company in Detroit, Amanda, a senior security consultant, scans several legacy Linux servers. On one host, she discovers an open port used for file transfer that allows anonymous login. Once connected, she is able to view the directory structure and check available files, which helps her identify potential sensitive information exposure. She also notices background traffic on a UDP service related to NetBIOS name lookups, but she continues probing the file transfer service to confirm user access

weaknesses. Which ports and services should Amanda prioritize for this enumeration activity?

- ☐ TCP 23 and UDP 137, 138
- ☐ TCP 139 and UDP 137, 138
- ☐ TCP 25 and UDP 138
- ☐ TCP 21 and UDP 137

88. During an external assessment of a healthcare insurance company in Houston, a penetration tester identifies a service running on TCP port 389. When queried, the service accepts anonymous binds and reveals directory data. By structuring his search filter, the tester is able to obtain usernames, departmental details, and organizational units. This information could potentially be used for targeted password attacks or privilege escalation. Which classification best describes this enumeration activity?

- ☐ DNS Enumeration
- ☐ LDAP Enumeration
- ☐ SMTP Enumeration
- ☐ NTP Enumeration

89. During a red team engagement at Apex Biotech in Dallas, ethical hacker Rachel calls the company's HR desk pretending to be Mark Stevens, a senior finance manager. She pressures the HR staffer by citing his "upcoming presentation for the CFO" and insists he urgently needs a copy of the updated employee benefits spreadsheet. The staffer feels compelled to help due to Rachel's convincing manner and authoritative tone. Which social engineering technique is Rachel demonstrating in this exercise?

- ☐ Impersonation
- ☐ Reverse Social Engineering

☐ Vishing

☐ Quid Pro Quo

90. You are a cybersecurity consultant at FortiSec, advising DesertTech Innovations in Phoenix, Arizona. The company wants to modernize its Wi-Fi so that even if an attacker obtains a captured handshake or a weak passphrase, they cannot perform offline dictionary attacks or recover session keys; management also wants stronger, per-session encryption and protection for IoT devices without relying on a single shared password. Which wireless security measure should DesertTech implement to meet these goals?

☐ Upgrade to WPA3

☐ MAC Address Filtering

☐ Disable TKIP

☐ Use 802.1X Authentication

91. During a penetration test at a logistics company in Atlanta, Georgia, you examine the configuration of network devices and discover that they rely on legacy communication mechanisms lacking encryption and integrity checks. These mechanisms allow neighboring systems to exchange operational data without verification, exposing the infrastructure to potential manipulation. What type of vulnerability is most clearly present?

☐ Firewall vulnerabilities

☐ Lack of password protection

☐ Insecure routing protocols

☐ Lack of authentication

92. During a penetration test at a financial services firm in Boston, ethical hacker

Daniel simulates a DDoS against the customer portal. To handle the surge, the IT team sets a rule that caps the number of requests a single user can make per second; aggressive connections are delayed or dropped while most legitimate customers continue to use the service. Which countermeasure strategy is the IT team primarily using?

- ☐ Absorb the Attack
- ☐ Rate Limiting
- ☐ Degrading Services
- ☐ Shutting Down Services

93. During an external security review of a manufacturing firm in Detroit, Michigan, you're asked to prioritize patch baselines for internet-facing servers without logging in or establishing full sessions. To achieve this, you analyze network-level responses and capture application output in order to determine the underlying system and its software release. Which technique best fits this objective?

- ☐ OS Discovery
- ☐ Service Version Discovery
- ☐ Port Scanning
- ☐ Vulnerability Scanning

94. During a penetration test at Cascade Financial in Seattle, ethical hacker Elena Vasquez probes the input handling of the company's web server. She discovers that a single crafted request is processed as two separate ones, allowing her to inject malicious data into the server's communication. This type of attack falls into the same category of input validation flaws as cross-site scripting (XSS), cross-site request forgery (CSRF), and SQL injection. Which type of web server attack is Elena most likely demonstrating?

- ☐ Web Cache Poisoning Attack
- ☐ Directory Traversal Attack
- ☐ Password Cracking Attack
- ☐ HTTP Response Splitting Attack

95. During a red team exercise at a technology consulting firm in San Francisco, analyst Evelyn deploys a malicious payload disguised within a software update installer. When the target runs the installer, the main application functions normally, but behind the scenes, additional malware components are silently placed on the system without the user's knowledge. These hidden components later activate to establish remote access for the red team. Which technique was most likely used to deliver the hidden malware?

- ☐ Downloader
- ☐ Injector
- ☐ Wrapper
- ☐ Dropper

96. During a red team engagement at a healthcare provider in Miami, ethical hacker Rachel suspects that a compromised workstation is running a sniffer in promiscuous mode. To confirm her suspicion, she sends specially crafted ICMP packets with a mismatched MAC address but a correct IP destination. Minutes later, the suspected machine responds to the probe even though ordinary systems would ignore it. Which detection technique is Rachel most likely using to validate the presence of a sniffer?

- ☐ ARP Method
- ☐ Nmap sniffer-detect (NSE)
- ☐ Ping Method

☐ DNS Method

97. During a penetration test at Cascade Biotech in Portland, Oregon, ethical hacker Olivia Harper installs a monitoring agent on a single test workstation inside the research subnet. The system records local events such as file access, configuration changes, and unauthorized process execution. Olivia explains to the security team that attackers often attempt to disable or evade this type of monitoring to avoid being detected at the host level. Which security system is Olivia most likely demonstrating?

☐ Network-Based Intrusion Detection System

☐ Host-Based Firewall

☐ Network-Based Firewall

☐ Host-Based Intrusion Detection System

98. During a penetration test at Pacific Shipping Co. in Seattle, ethical hacker Mia Chen evaluates the defenses protecting the company's web-facing servers. She observes that the security system is not only checking basic packet headers but also validating session state and performing some application-level analysis. This multilayer approach makes it more difficult for Mia to bypass the firewall using simple fragmentation or tunneling attacks. Which type of firewall is Mia most likely facing?

☐ Application-Level Firewall

☐ Stateful Multilayer Inspection Firewall

☐ Circuit-Level Gateway Firewall

☐ Packet Filtering Firewall

99. During a penetration test at a healthcare facility in Baltimore, Maryland, an ethical hacker demonstrates how attackers are mapping active hosts and open

ports using ICMP-based techniques. To reduce the organization's exposure, the security team decides to implement a countermeasure that specifically disrupts ICMP discovery traffic by preventing error messages from being returned. Which action should they take?

- ☐ Configure firewall and IDS rules to detect and block probes
- ☐ Block inbound ICMP message types and all outbound ICMP type-3 unreachable messages
- ☐ Block unwanted services running on the ports and update the service versions
- ☐ Use a custom rule set to lock down the network, block unwanted ports at the firewall, and filter specific ports

100. During a red team assessment at a university in Chicago, Jake, a penetration tester, scans a group of older Windows workstations in the administration department. On several hosts, he notices traffic on UDP ports 137 and 138 as well as an open TCP port 139. Curious, he uses a utility to query the name table and session services. Within moments, he collects information including machine names, logged-in usernames, and available shared folders without authentication. Which enumeration method is being demonstrated in this scenario?

- ☐ NetBIOS Enumeration
- ☐ NFS Enumeration
- ☐ SMB Enumeration
- ☐ SNMP Enumeration

101. You are an ethical hacker at Sentinel Cyberworks, engaged to assess the wireless defenses of HarborTrust Bank in Portland, Oregon. During your assessment the security team shows you a production system that continuously places selected APs into a passive scan mode, aggregates alarms from multiple wireless controllers into a central engine for forensic storage, and can

automatically apply countermeasures (for example, time-sliced channel scanning and remote configuration changes) across the campus when it classifies a nearby device as malicious. Based on the described capabilities, which Wi-Fi security solution is this most consistent with?

- ☐ WatchGuard Wi-Fi Cloud WIPS
- ☐ Cisco Adaptive Wireless IPS
- ☐ FortiWLC Controller
- ☐ RFProtect

102. At Horizon Legal Services in Boston, Massachusetts, ethical hacker Daniel Price is tasked with assessing the security of the firm's mobile case-tracking app. During testing, he finds that confidential case notes and client records are kept locally on the device without encryption. By browsing the file system with a standard explorer tool, he can open sensitive information without any authentication. Which OWASP Top 10 Mobile Risk is most clearly present in the app?

- ☐ Improper Credential Usage
- ☐ Insecure Data Storage
- ☐ Inadequate Privacy Controls
- ☐ Insecure Communication

103. During a quarterly vulnerability management review at RedCore Motors, Priya finalizes the deployment of Nessus Essentials across the company's IT infrastructure. The solution is selected for its ability to support diverse technologies including operating systems, databases, web servers, and virtual environments. While preparing a training session for junior analysts, Priya asks them to identify a capability that Nessus Essentials is specifically designed to provide as part of its scanning process.

- ☐ Agent-based detection
- ☐ Patch management for operating systems and third-party applications
- ☐ High-speed asset discovery
- ☐ Checks for outdated versions of over 1200 servers

104. During a covert assessment at a logistics company in Dallas, penetration tester Emily delivers a disguised attachment to test employee awareness. When a staff member opens the file, normal content appears, but behind the scenes the attacker quietly gains full access to the workstation. Over the following week, Emily monitors emails, keystrokes, and local files without alerting the user, confirming long-term stealthy control of the machine. Which type of malware is most likely responsible for this activity?

- ☐ Botnet
- ☐ Remote Access Trojan (RAT)
- ☐ Adware
- ☐ Spyware

105. In the bustling city of Chicago, Illinois, ethical hacker Sophia Nguyen is contracted by TaskFlow Systems, a U.S.-based project management provider, to review the security of its template upload feature. During testing, Sophia discovers that by modifying the input parameters in an upload request, she can trick the application into retrieving sensitive files from the server's local directories. This flaw allows her to view internal configuration files that should never be exposed through the web interface. She records her findings in a report for TaskFlow's security team.

- ☐ Local File Inclusion
- ☐ FTP Injection
- ☐ Insecure Deserialization

☐ Cookie Poisoning

106. A biotech research firm in Boston, Massachusetts, migrates its laboratory management platform to the cloud. The vendor provides an environment where developers can deploy and test custom applications without managing the underlying servers, operating systems, or storage. The firm controls the application logic but not the runtime infrastructure. Which cloud service model is the company using?

☐ Infrastructure as a Service (IaaS)

☐ Software as a Service (SaaS)

☐ Platform as a Service (PaaS)

☐ Anything as a Service (XaaS)

107. During a controlled red team engagement at a financial institution in New Jersey, ethical hacker Ryan tests the bank's resilience against stealth-based malware. He plants a custom malicious program on an employee workstation. After execution, he observes that the infected files continue to function normally, but his malware conceals its modifications by intercepting operating system calls. Antivirus scans repeatedly return "no threats detected," even though the malicious code remains active and hidden on the system. Which type of virus did Ryan most likely deploy in this assessment?

☐ Stealth Virus

☐ Polymorphic Virus

☐ Cavity Virus

☐ Macro Virus

108. In the sunlit tech oasis of Phoenix, Arizona, ethical hacker Nadia Patel explores the security posture of LearnSphere, a U.S.-based e-learning platform

serving thousands of students. During her testing, Nadia intentionally submits invalid inputs to the platform's content delivery system. Instead of returning a generic failure notice, the application responds with detailed system information, including database query strings and directory paths. Such responses provide attackers with valuable insights into the application's internal workings, which could be used to craft more precise and damaging attacks.

- ☐ Directory Traversal
- ☐ CORS Misconfiguration
- ☐ Improper Error Handling
- ☐ Verbose Error Messages

109. During a penetration test at Sunshine Media's streaming platform in Miami, ethical hacker Sofia Alvarez examines whether the company's web server exposes sensitive resources through poor configuration. She finds that a crawler directive at the server's root allows unintended indexing of restricted areas. This oversight reveals internal paths that may expose hidden links, confidential files, or other sensitive information. Which technique is Sofia most likely using in this assessment?

- ☐ Directory Brute Forcing
- ☐ Web Server Footprinting/Banner Grabbing
- ☐ Information Gathering from Robots.txt File
- ☐ Vulnerability Scanning

110. While conducting a red team exercise at a corporate office in San Diego, California, you observe employees working in an open-plan area. By discreetly watching their screens and hand movements as they log into internal systems, you are able to capture several usernames and partial passwords without touching any devices or interacting with the staff. Which social engineering technique does this scenario best illustrate?

☐ Dumpster Diving

☐ Tailgating

☐ Impersonation

☐ Shoulder Surfing

111. During a penetration test at Cascade Financial in Raleigh, ethical hacker Ethan Brooks evaluates the security of the company's authentication system. He observes that the application accepts a high volume of repeated credential submissions without introducing any additional challenge, allowing automated scripts to cycle rapidly through large password lists. Ethan advises the IT team to deploy a control that forces interaction steps designed to disrupt automation. Which countermeasure should the IT team adopt in this scenario?

☐ Use CAPTCHA challenges on login and registration pages

☐ Implement 2FA/MFA

☐ Force periodic password changes

☐ Use strong hashing algorithms

112. During a penetration test at Horizon Tech in Austin, ethical hacker Michael sets up a man-in-the-middle attack to intercept traffic between employees and the company's internal web applications. He uses a lightweight tool capable of performing ARP spoofing, DNS manipulation, and packet injection while providing an interactive interface for real-time monitoring. This allows him to capture and manipulate session tokens in transit, which he later presents to the security team as proof of risk. Which tool is Michael most likely using in this exercise?

☐ Ettercap

☐ Wireshark

☐ Cain

☐ Bettercap

113. During a red team assessment at Sunshine Credit Union in Miami, ethical hacker Laura demonstrates a weakness in the company's session handling process. She shows that once a user logs in, the same authentication token assigned before login continues to be valid without being refreshed. Laura explains that an attacker could exploit this flaw by tricking a victim into authenticating with a value already known to the attacker, gaining access afterward. To mitigate this risk, the IT team agrees to apply a countermeasure focused on proper session lifecycle management. Which countermeasure should the IT team implement?

☐ Implement SSL to encrypt all information in transit via the network

☐ Use restrictive cache directives for all the web traffic through HTTP and HTTPS

☐ Regenerate the session ID after a successful login to prevent session fixation attacks

☐ Do not create sessions for unauthenticated users unless necessary

114. You are Jordan, a cryptographic assessor at Cascade Data in Portland, Oregon, reviewing the protections applied to telemetry logs. Your review finds an algorithm that operates on 128-bit blocks, accepts keys up to 256 bits, and the documentation notes it was one of the finalists in the AES selection process that aimed to replace legacy DES. Which symmetric encryption algorithm should you identify as being used?

☐ Blowfish

☐ Twofish

☐ RC4

☐ AES

115. During a penetration test at a financial services company in Denver, ethical hacker Jason demonstrates how employees could be tricked by a rogue DHCP server. To help the client prevent such attacks in the future, Jason shows the administrators how to configure their Cisco switches to reject DHCP responses from untrusted ports. He explains that this global setting must be activated before more granular controls can be applied. Which switch command should Jason recommend to implement this defense?

- ☐ Switch(config)# ip dhcp snooping
- ☐ Switch(config)# ip dhcp snooping trust
- ☐ Switch(config)# arp inspection vlan 10
- ☐ Switch(config)# ip dhcp snooping vlan 10

116. You are Evelyn, an ethical hacker at LoneStar Health in Austin, Texas, engaged to investigate a recent compromise of archived patient records. During the investigation you recover a large set of encrypted records from a compromised backup and, separately, obtain several original template records (standard headers and form fields) that correspond to some entries in the encrypted set. You plan to use these paired examples (the original templates and their encrypted counterparts) to attempt to recover keys or deduce other plaintext values. Which cryptanalytic approach is most appropriate for this situation?

- ☐ Chosen-plaintext attack
- ☐ Ciphertext-only attack
- ☐ Known-plaintext attack
- ☐ Chosen-ciphertext attack

117. At a smart retail outlet in San Diego, California, ethical hacker Sophia Bennett assesses IoT-based inventory sensors that synchronize with a cloud dashboard. She discovers that sensitive business records are sent across the

network without encryption and are also stored in a retrievable format on the provider's cloud platform. Which IoT attack surface area is most directly demonstrated in this finding?

- ☐ Insecure data transfer and storage
- ☐ Insecure network services
- ☐ Insecure default settings
- ☐ Insecure ecosystem interfaces

118. During a red team assessment at New England Insurance in Boston, ethical hacker Daniel sends a series of spoofed TCP packets carrying the reset flag to a server hosting client applications. As a result, several active sessions between employees and the server are abruptly terminated, causing temporary disruption of legitimate work. Daniel uses this demonstration to highlight how attackers can forcibly tear down sessions without completing a full hijack. Which type of network-level session hijacking technique is Daniel simulating?

- ☐ Blind Hijacking
- ☐ RST Hijacking
- ☐ TCP/IP Hijacking
- ☐ UDP Hijacking

119. During a penetration test at Windy City Enterprises in Chicago, ethical hacker Mia Torres targets the company's public-facing site. By exploiting an unpatched vulnerability in the web server, she manages to alter visible content on the homepage, replacing it with unauthorized messages. Mia explains to the IT team that this kind of attack can damage the company's reputation and erode customer trust, even if sensitive data is not directly stolen. Which type of web server attack is Mia most likely demonstrating?

- ☐ File Upload Exploits

☐ Website Defacement

☐ Frontjacking

☐ DNS Hijacking

120. At a Los Angeles-based online gaming company, penetration tester John investigates a recent cloud breach that caused downtime and delayed alerts. He finds that the root issue was management's lack of defined responsibilities for monitoring, auditing, and securing serverless services, which left critical functions unmanaged. Which cloud computing threat does this scenario best illustrate?

☐ Data Governance

☐ Side-channel attacks

☐ Privilege escalation

☐ Insufficient logging and monitoring

121. While reviewing exposed infrastructure for a logistics company in Denver, Joe, a security analyst, identifies that one host is synchronizing time using UDP port 123. Probing further, he issues queries to extract details about peers, offsets, and delays. This allows him to gather internal hostnames and client IP addresses connected to the time server. Such information leakage could provide insight into the company's internal network structure. Which technique was most likely used to obtain this information?

☐ NetBIOS Enumeration

☐ NTP Enumeration

☐ DNS Zone Transfer Enumeration

☐ VoIP Enumeration

122. You are an ethical hacker at Apex Cyber Defense contracted to audit Coastal Healthcare's wireless estate in Miami, Florida. During a network sweep, your logs show a previously unknown access point physically connected to the hospital's internal switch and issuing IP addresses to devices on the corporate VLAN — it was neither provisioned by IT nor listed in the asset inventory. The device is relaying internal traffic and providing remote connectivity back to an external host. Based on the observed behavior, which wireless threat has the attacker most likely introduced?

- ☐ Evil Twin AP
- ☐ Rogue AP
- ☐ Honeypot AP
- ☐ Misconfigured AP

123. During a penetration test at a technology startup in Austin, Texas, an ethical hacker is tasked with evaluating defenses against stealthy scanning techniques. She selects an approach that involves sending TCP packets with no flags, relying on the way target systems respond to infer whether ports are open or closed. This allows her to remain less visible to intrusion detection systems compared to a full handshake. Which scanning method is she using?

- ☐ NULL Scan
- ☐ TCP Connect Scan
- ☐ ACK Scan
- ☐ FIN Scan

124. You are Riley, an incident responder at NovaEx Crypto in San Antonio, Texas, tasked with investigating a recent double-spend reported by a retail merchant that accepts the exchange's token. Your telemetry shows that a reseller node used by the merchant received blocks only from a small, fixed set of peers for several hours and accepted a conflicting history that later allowed the attacker to

reverse a confirmed payment. The attacker appears to have controlled which peers that node communicated with and supplied it a private chain until they were ready to reveal it. Which blockchain attack does this behavior most closely describe?

- ☐ 51% Attack
- ☐ Eclipse Attack
- ☐ DeFi Sandwich Attack
- ☐ Finney Attack

125. During a penetration test at a retail company in Seattle, Washington, an ethical hacker needs to disguise her scans so they appear to originate from a specific hardware vendor. The organization uses MAC-based logging, and by assigning a vendor-associated identifier, she can make her traffic blend in with legitimate devices on the network. Which Nmap command should she use to achieve this?

- ☐ `nmap -sT -Pn --spoof-mac 0 10.10.1.11`
- ☐ `nmap -sT -Pn --spoof-mac Dell 10.10.1.11`
- ☐ `nmap -sT -Pn --spoof-mac 00:11:22 10.10.1.11`
- ☐ `nmap -sT -Pn --spoof-mac 00:0D:22:56:AE:10 10.10.1.11`

題號	解答 (Answer)
1	Call Spoofing
2	hashdump
3	Confidentiality
4	IP Identification Number (IPID) Monitoring
5	Active Session Hijacking
6	Privilege Escalation Using DLL Hijacking
7	Semi-untethered Jailbreaking
8	Use an Intrusion Detection System (IDS)
9	Passive attack
10	MX
11	Firmware update attack

題號	解答 (Answer)
12	Botnet Agents
13	Anomaly-Based Detection
14	Traffic IQ Professional
15	MAC Flooding
16	Password Spraying
17	Registry run keys
18	Expansion
19	Vulnerability scanning
20	Wireshark
21	Vulnerability Scanning
22	Verification

題號	解答 (Answer)
23	Whaling
24	Measured service
25	Distributed Control System (DCS)
26	BitLocker Drive Encryption
27	Fileless Malware
28	Cryptographic Failures
29	Credentialed Scanning
30	HTTP Response Splitting
31	UNION SQL Injection
32	HTTP GET/POST Attack
33	Predictive analysis

題號	解答 (Answer)
34	Ensure secure boot
35	Include quantum-resistance checks in SDLC and code review processes
36	ARP Spoofing
37	Hardware/Firmware Rootkit
38	Web Application Firewall
39	Network-based Scanning
40	SYN Flood Attack
41	Packet Fragmentation
42	Teardrop Attack
43	Review permissions requested by apps before installing them
44	Boolean Exploitation

題號	解答 (Answer)
45	Tailgating
46	Use parameterized queries or prepared statements
47	Active Footprinting
48	It is an APK that can run directly on the device without a PC
49	Follow TCP Stream
50	Whois lookup
51	On-demand self-service
52	Delivery
53	Shell Injection
54	Container orchestration
55	Airodump-ng

題號	解答 (Answer)
56	HTTP Tunneling
57	filetype:pdf intitle:"admin access" site:onion
58	Black Hat hackers
59	WPA2
60	Spam and Phishing
61	Rogue DHCP Server Attack
62	Creepy
63	ISO/IEC 27005:2022
64	Assessment Overview
65	Testing String
66	Register devices with a remote locate and wipe facility

題 號	解答 (Answer)
67	Distributed Reflection Denial-of-Service (DRDOS)
68	Pass-the-Ticket Attack
69	Design Flaws
70	Employees must verify the identity of individuals requesting information
71	Sender's IP address
72	Information Gathering and Vulnerability Detection
73	Compromising secrets
74	Worm
75	Application Keylogger
76	Hoax
77	Document Root

題號	解答 (Answer)
78	Block all unnecessary ports, ICMP traffic, and protocols
79	ms-sql-m
80	Analyzing Response Time
81	dig @ axfr
82	ntpd -i lnps [-c command] [host] [...]
83	Session Fixation Attack
84	In-line Comment
85	DSA
86	Social Engineering
87	TCP 21 and UDP 137
88	LDAP Enumeration

題號	解答 (Answer)
89	Impersonation
90	Upgrade to WPA3
91	Insecure routing protocols
92	Rate Limiting
93	OS Discovery
94	HTTP Response Splitting Attack
95	Wrapper
96	Ping Method
97	Host-Based Intrusion Detection System
98	Stateful Multilayer Inspection Firewall
99	Block inbound ICMP message types and all outbound ICMP type-3

題 號	解答 (Answer)
	unreachable messages
100	NetBIOS Enumeration
101	Cisco Adaptive Wireless IPS
102	Insecure Data Storage
103	High-speed asset discovery
104	Remote Access Trojan (RAT)
105	Local File Inclusion
106	Platform as a Service (PaaS)
107	Stealth Virus
108	Verbose Error Messages
109	Information Gathering from Robots.txt File

題號	解答 (Answer)
110	Shoulder Surfing
111	Use CAPTCHA challenges on login and registration pages
112	Bettercap
113	Regenerate the session ID after a successful login to prevent session fixation attacks
114	Twofish
115	Switch(config)# ip dhcp snooping
116	Known-plaintext attack
117	Insecure data transfer and storage
118	RST Hijacking
119	Website Defacement

題 號	解答 (Answer)
120	Insufficient logging and monitoring
121	NTP Enumeration
122	Rogue AP
123	NULL Scan
124	Eclipse Attack
125	<code>nmap -sT -Pn --spoof-mac Dell 10.10.1.11</code>